

privacy-by-design-checklist

Article 25 assessment v0.1.0

Privacy by Design Assessment

System: AI meeting notetaker for internal calls

System ID: MEETING-NOTES-001

Organisation: Example Professional Services Ltd

Purpose: Capture meeting notes and follow-ups for internal staff calls

Description: Proposed tool that records meetings, generates transcripts, and stores action items for a professional-services firm.

Generated (UTC): 2026-09-01 13:55

Principle score: 67.3/100

Default score: 25.0/100

Notes: Recording and transcript storage are on for every call by default. No retention job for audio or transcripts. DPIA started but not finished. Admin export uses a shared password today. People can still take typed notes without the AI tool.

Overall band:

PARTIAL

Art. 25(2) gate: at least one default-settings answer is NO, so PASS is blocked.

Decision-support only. Not legal advice. Review with a DPO before go-live.

Seven privacy-by-design principles

Proactive: 83.3/100

Proactive not reactive; preventative not remedial

Default: 33.3/100

Privacy as the default setting

Embedded: 50.0/100

Privacy embedded into design

Full functionality: 100.0/100

Full functionality - positive-sum, not zero-sum

Security: 62.5/100

End-to-end security - full lifecycle protection

Transparency: 66.7/100

Visibility and transparency - keep it open

User-centric: 75.0/100

Respect for user privacy - keep it user-centric

Privacy by default (Article 25(2))

Amount of personal data collected: no (0.0/100) BLOCKS PASS

Extent of processing: partial (50.0/100)

Period of storage: no (0.0/100) BLOCKS PASS

Accessibility: partial (50.0/100)

Engineer go-live checklist

1. [NO] Amount of personal data collected (amount; Art. 25)

By default, does the system collect only the personal data needed for its stated purpose?

2. [NO] Period of storage (storage; Art. 25)

By default, is a retention period set and enforced?

3. [PARTIAL] Extent of processing (extent; Art. 25)

By default, is processing limited to that purpose (no extra matching, profiling, or sharing)?

4. [PARTIAL] Accessibility (accessibility; Art. 25)

By default, can only people who need it access the personal data?

5. [NO] Security (p5-disposal; Art. 5, 32)

Is there a defined, enforced way to delete or dispose of personal data at end of life?

6. [PARTIAL] Security (p5-access-control; Art. 32)

Is admin access role-based, with MFA for privileged roles?

7. [NO] Default (p2-opt-in; Art. 25, 5)

Is extra collection opt-in rather than opt-out?

8. [PARTIAL] Transparency (p6-audit; Art. 5)

Can the organisation show who decided the design and what was accepted?

9. [NO] Default (p2-optional-off; Art. 25)

Are optional features that collect extra personal data off by default?

10. [PARTIAL] Proactive (p1-high-risk; Art. 25, 35)

Has high-risk processing been identified, and is a DPIA planned if needed?

11. [PARTIAL] Embedded (p3-in-architecture; Art. 25)

Are privacy controls in the architecture, not only in a policy document?

12. [PARTIAL] Embedded (p3-design-records; Art. 25)

Are privacy requirements written into the design, not added after launch?

13. [PARTIAL] Transparency (p6-notice; Art. 13, 14)

Is there a clear privacy notice for the people this system is about?

14. [PARTIAL] User-centric (p7-rights; Art. 15, 17)

Is there a way to handle access, erasure, and similar rights for this data?